

Clase 251 — OSINT de empresas y dominios

Parte: **12 — OSINT e ingeniería social** · Fuente: *Open Source Intelligence Techniques* (M. Bazzell) · OWASP WSTG (Information Gathering) 🕒 Duración estimada: **110 min** · Nivel: **Intermedio**

🎯 Objetivo

Mapear la superficie pública de una organización a partir de su dominio: WHOIS, DNS, subdominios, certificados, correos corporativos, tecnologías y filtraciones en repositorios. El alumno terminará capaz de producir un inventario de exposición que alimente tanto un pentest autorizado como un plan de reducción de huella corporativa.

⚖️ Nota ética

Realiza estas técnicas contra **dominios propios, de laboratorio (p. ej. `example.com`, `scanme.nmap.org`) o de un cliente con autorización escrita**. La resolución DNS pasiva y los registros públicos son de bajo riesgo, pero el escaneo activo del dominio requiere permiso.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Consultar** WHOIS y registros DNS para reconstruir la infraestructura de un dominio.
- 2. **Enumerar** subdominios de forma pasiva mediante Certificate Transparency y fuentes públicas.
- 3. **Descubrir** correos y patrones de nomenclatura corporativa.
- 4. **Identificar** tecnologías y servicios expuestos.
- 5. **Detectar** filtraciones en repositorios y buscar secretos expuestos.

📖 Temas

#	Tema	Por qué importa
1	WHOIS y registrantes	Revela titularidad y contactos
2	Registros DNS (A, MX, TXT, NS)	Mapa de servidores y correo
3	Certificate Transparency	Subdominios sin tocar el objetivo
4	Enumeración de subdominios	Amplía la superficie de ataque
5	Correos y nomenclatura	Base para phishing autorizado
6	Fingerprinting tecnológico	Prioriza vectores conocidos
7	Filtraciones en repos/buckets	Secretos y código expuesto

Definiciones y características

- **WHOIS:** base de datos de registro de dominios/IP. Característica: cada vez más ofuscada por privacidad, pero útil por fechas y NS.
- **Certificate Transparency (CT):** logs públicos de certificados TLS emitidos. Característica: revela subdominios sin consultar al objetivo.
- **Enumeración pasiva de subdominios:** descubrir hosts sin enviar tráfico al objetivo. Característica: casi indetectable.
- **Registro TXT/SPF/DMARC:** políticas de correo publicadas en DNS. Característica: indican si el dominio es fácil de suplantar.
- **Fingerprinting:** identificar tecnologías (CMS, servidor, framework). Característica: guía la explotación posterior.
- **Secreto expuesto:** clave/API filtrada en un repo o bucket. Característica: hallazgo de alto impacto y crítico de reportar.

Herramientas y preparación

- **DNS/WHOIS:** `whois`, `dig`, `host`, `dnsrecon`.
- **Subdominios pasivos:** `subfinder`, `amass enum -passive`, `crt.sh` (`https://crt.sh/?q=%25.example.com`).
- **Correos y tecnologías:** `theHarvester`, `Wappalyzer`, `httpx`, `BuiltWith`.
- **Filtraciones:** GitHub dorks, `trufflehog`, `gitleaks`, buscadores de buckets S3.
- **Recordatorio:** favorece fuentes pasivas; el escaneo activo solo con autorización del alcance.

Laboratorio guiado

Objetivo autorizado: usa `example.com` y un dominio propio.

1. WHOIS y fechas: `whois example.com` — anota registrador, fechas y NS.
2. Registros DNS: `dig example.com ANY +noall +answer` y `dig MX example.com`.
3. Política de correo: `dig TXT example.com` — busca SPF y `dig TXT _dmarc.example.com` para DMARC.
4. Subdominios por CT: abre `https://crt.sh/?q=%25.tudominio.com` y exporta la lista.
5. Enumeración pasiva: `subfinder -d tudominio.com -silent` y `amass enum -passive -d tudominio.com`.
6. Hosts vivos: `subfinder -d tudominio.com -silent | httpx -title -tech-detect`.
7. Correos y perfiles: `theHarvester -d tudominio.com -b bing,crtsh`.
8. Filtraciones: busca en GitHub `"tudominio.com" password` y ejecuta `trufflehog git <repo-propio>`.
9. Consolida todo en un inventario de exposición con severidad y recomendación.

Ejercicios

1. Compara los subdominios que devuelven `crt.sh`, `subfinder` y `amass`; explica las diferencias.
2. Evalúa el SPF/DMARC de un dominio y decide si es suplantable.
3. Clasifica 5 subdominios por riesgo (panel de login, dev, staging, etc.).
4. Ejecuta `httpx -tech-detect` y prioriza 3 tecnologías por CVE conocido.
5. Deriva el patrón de correo corporativo (`nombre.apellido@`) a partir de ejemplos públicos.

6. Documenta un secreto ficticio "encontrado" y redacta la sección de reporte responsable.

Reto verificable

Produce un **inventario de exposición** de un dominio autorizado con: subdominios vivos, tecnologías, política de correo (SPF/DMARC) y al menos 3 recomendaciones priorizadas. **Criterio de aceptación:** todos los subdominios se obtuvieron con métodos pasivos reproducibles y el inventario indica, por cada ítem, la fuente y la acción de remediación sugerida.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
WHOIS "redacted for privacy"	Ofuscación WHOIS. Pivota vía CT, DNS histórico y NS.
Pocos subdominios encontrados	Solo se usó una fuente. Combina crt.sh + subfinder + amass.
<code>httpx</code> marca todo como vivo	Comodines DNS. Filtra por código/título y valida manualmente.
Falsos secretos en trufflehog	Entropía alta pero no es clave. Verifica el contexto antes de reportar.
Escaneo bloqueado	Se hizo activo sin permiso o el WAF bloqueó. Mantente en pasivo salvo autorización.

Preguntas frecuentes

 **¿crt.sh es OSINT pasivo?** Sí: consulta logs públicos de certificados, no toca la infraestructura del objetivo, por lo que no genera tráfico hacia él.

 **¿Encontré una clave en GitHub, qué hago?** Repórtalo por canal responsable al dueño, no la uses. En un engagement, documéntalo como hallazgo crítico dentro del alcance acordado.

 **¿SPF/DMARC importan para OSINT?** Mucho: un dominio sin DMARC en `p=reject` es candidato a suplantación en una campaña de phishing autorizada.

Referencias

- Bazzell, M. *Open Source Intelligence Techniques*. <https://inteltechniques.com/book1.html>
- OWASP WSTG — Information Gathering. <https://owasp.org/www-project-web-security-testing-guide/>
- crt.sh (Certificate Transparency). <https://crt.sh/>
- Subfinder. <https://github.com/projectdiscovery/subfinder>
- theHarvester. <https://github.com/laramies/theHarvester>

Siguiente clase

Clase 252 - OSINT en redes sociales